rKGeN Move

Audit Report

contact@bitslab.xyz

https://twitter.com/movebit_

Wed Jan 15 2025

rKGeN Move Audit Report

1 Executive Summary

1.1 Project Information

Description	The rKGen token on the Aptos blockchain will follow the Fungible Asset Standard, featuring controlled minting/burning via multisig wallet approvals (e.g., msafe). Token transfers are restricted to authorized treasury addresses, with freeze/unfreeze mechanisms for added security. Built using Move, the contract employs role-based access control (RBAC), on-chain views, and events for transparency
Type	Token
Auditors	MoveBit
Timeline	Tue Jan 07 2025 - Wed Jan 15 2025
Languages	Move
Platform	Aptos
Methods	Architecture Review, Unit Testing, Manual Review
Source Code	https://github.com/kgen-protocol/smartcontracts
Commits	40c6c1067b5bd3d2107472fcebacae4bf923bba279ac1e40567622de0534216a0d95e644cfa78423a971d6fc010f0fe650fc4f8d3008258488d7fd03

1.2 Files in Scope

The following are the SHA1 hashes of the original reviewed files.

ID	File	SHA-1 Hash
MOV6	rKGEN-Core-SC/rKGEN/Move.toml	87d92ca611805faad6c01096b560da6b737cd238
RKGEN	rKGEN-Core-SC/rKGEN/sources/rKGEN.move	bd746aef5c90adb47a71cd49c53b6d8214cd0db5

1.3 Issue Statistic

Item	Count	Fixed	Acknowledged
Total	4	3	1
Informational	2	1	1
Minor	1	1	0
Medium	1	1	0
Major	0	0	0
Critical	0	0	0

1.4 MoveBit Audit Breakdown

MoveBit aims to assess repositories for security-related issues, code quality, and compliance with specifications and best practices. Possible issues our team looked for included (but are not limited to):

- Transaction-ordering dependence
- Timestamp dependence
- Integer overflow/underflow by bit operations
- Number of rounding errors
- Denial of service / logical oversights
- Access control
- Centralization of power
- Business logic contradicting the specification
- Code clones, functionality duplication
- Gas usage
- Arbitrary token minting
- Unchecked CALL Return Values
- The flow of capability
- Witness Type

1.5 Methodology

The security team adopted the **"Testing and Automated Analysis"**, **"Code Review"** and **"Formal Verification"** strategy to perform a complete security test on the code in a way that is closest to the real attack. The main entrance and scope of security testing are stated in the conventions in the "Audit Objective", which can expand to contexts beyond the scope according to the actual testing needs. The main types of this security audit include:

(1) Testing and Automated Analysis

Items to check: state consistency / failure rollback / unit testing / value overflows / parameter verification / unhandled errors / boundary checking / coding specifications.

(2) Code Review

The code scope is illustrated in section 1.2.

(3) Formal Verification(Optional)

Perform formal verification for key functions with the Move Prover.

(4) Audit Process

- Carry out relevant security tests on the testnet or the mainnet;
- If there are any questions during the audit process, communicate with the code owner in time. The code owners should actively cooperate (this might include providing the latest stable source code, relevant deployment scripts or methods, transaction signature scripts, exchange docking schemes, etc.);
- The necessary information during the audit process will be well documented for both the audit team and the code owner in a timely manner.

2 Summary

This report has been commissioned by KGeN to identify any potential issues and vulnerabilities in the source code of the rKGeN Move smart contract, as well as any contract dependencies that were not part of an officially recognized library. In this audit, we have utilized various techniques, including manual code review and static analysis, to identify potential vulnerabilities and security issues.

During the audit, we identified 4 issues of varying severity, listed below.

ID	Title	Severity	Status
RKG-1	Single-step Ownership Transfer Can be Dangerous	Medium	Fixed
RKG-2	Missing Validation for Non-Zero amount	Minor	Fixed
RKG-3	Mismatch Between Commented Supply and Actual Value	Informational	Acknowledged
RKG-4	Missing Event Emission for AddedSenderAddress	Informational	Fixed

3 Participant Process

Here are the relevant actors with their respective abilities within the rKGeN Move Smart Contract :

Admin

- `update_admin` : Updates the admin of the module to a new address.
- `update_minter` : Updates the minter address for the module.
- `add_treasury_address` : Adds a new address to the treasury list.
- `remove_treasury_address` : Removes an existing address from the treasury list.
- `add_whitelist_sender` : Adds a new address to the whitelist of senders.
- `remove_whitelist_sender` : Removes an existing address from the whitelist of senders.
- `add_whitelist_receiver` : Adds a new address to the whitelist of receivers.
- `remove_whitelist_receiver` : Removes an existing address from the whitelist of receivers.
- `freeze_account` : Freezes an account, preventing transfers or receipt of assets.
- `unfreeze_account` : Unfreezes an account, restoring transfer and receipt capabilities.
- `burn` : Burns a specified amount of fungible assets from a given address.

User

- `mint` : Mints tokens to a specified address. This function is restricted to a multisig wallet as the minter role.
- `transfer` : Executes a token transfer between accounts, ensuring the sender and receiver comply with whitelist rules.

4 Findings

RKG-1 Single-step Ownership Transfer Can be Dangerous

Severity: Medium

Status: Fixed

Code Location:

rKGEN-Core-SC/rKGEN/sources/rKGEN.move#357-382

Descriptions:

Single-step ownership transfer means that if a wrong address was passed when transferring ownership or admin rights it can mean that role is lost forever. If the admin permissions are given to the wrong address within this function, it will cause irreparable damage to the contract. The `update_admin()` function directly transfers the admin role to a new address, which poses the above-mentioned risks.

```
public entry fun update_admin(admin_addr: &signer, new_admin: address) acquires
Admin {
    // Ensure that only admin can add a new admin
    assert_admin(admin_addr);

    // Ensure that new_admin should be a valid address
    assert!(
        new_admin != @0x0 &&
!system_addresses::is_framework_reserved_address(new_admin),
        error::unauthenticated(ENOT_VALID_ADDRESS)
    );
    assert!(
        signer::address_of(admin_addr) != new_admin,
        error::already_exists(EALREADY_EXIST)
    );

    // Get the Admin Role storage reference
    let admin_struct = borrow_global_mut<Admin>(@rKGenAdmin);
    // Add the new admin
    admin_struct.admin = new_admin;

    event::emit(
```

```
        UpdatedAdmin {
            role: to_string(&std::string::utf8(b"New Admin Added")),
            added_admin: new_admin
        }
    );
}
```

Suggestion:

It is recommended to use a two-step ownership transfer process.

Resolution:

This issue has been fixed. The client has adopted our suggestions.

RKG-2 Missing Validation for Non-Zero amount

Severity: Minor

Status: Fixed

Code Location:

rKGEN-Core-SC/rKGEN/sources/rKGEN.move#293,307,334,623

Descriptions:

Operations such as `mint`, `transfer`, `burn`, and `withdraw` do not include a validation check to ensure that the amount is greater than zero.

Suggestion:

Implement a validation check in all relevant functions to ensure the amount is greater than zero before proceeding.

This ensures only meaningful operations are performed and explicitly handle errors.

Resolution:

This issue has been fixed. The client has adopted our suggestions.

RKG-3 Mismatch Between Commented Supply and Actual Value

Severity: Informational

Status: Acknowledged

Code Location:

rKGEN-Core-SC/rKGEN/sources/rKGEN.move#238

Descriptions:

```
primary_fungible_store::create_primary_store_enabled_fungible_asset(
    constructor_ref,
    option::some(200_000_000_00000000), /* Supply 200* 10^8 (8 decimals)*/
    utf8(METADATA_NAME), /* name */
    utf8(ASSET_SYMBOL), /* symbol */
    8, /* decimals */
    utf8(ICON_URI), /* icon */
    utf8(PROJECT_URI) /* project */
);
```

In the `init_module` function, the supply value `200_000_000_00000000` in the code does not match the commented value of 200 * 10^8.

Suggestion:

Review the expected supply amount and update either the code or the comment to ensure consistency.

Resolution:

After communication with the project team, it has been confirmed that the total supply of the asset is defined as 200 million (200M) during deployment.

RKG-4 Missing Event Emission for AddedSenderAddress

Severity: Informational

Status: Fixed

Code Location:

rKGEN-Core-SC/rKGEN/sources/rKGEN.move#464

Descriptions:

In the `add_treasury_address` function, there are two key operations: adding a new address to the `treasury_vec` and adding it `tosender_vec` if certain conditions are met. However, only the `AddedTreasuryAddress` event is emitted, leaving the addition to the `sender_vec` undocumented through an event.

Suggestion:

Emit an additional `AddedSenderAddress` event whenever a new address is added to the `sender_vec`. This ensures that all relevant operations are logged and improves traceability.

Resolution:

This issue has been fixed. The client has adopted our suggestions.

Appendix 1

Issue Level

- **Informational** issues are often recommendations to improve the style of the code or to optimize code that does not affect the overall functionality.
- **Minor** issues are general suggestions relevant to best practices and readability. They don't post any direct risk. Developers are encouraged to fix them.
- **Medium** issues are non-exploitable problems and not security vulnerabilities. They should be fixed unless there is a specific reason not to.
- **Major** issues are security vulnerabilities. They put a portion of users' sensitive information at risk, and often are not directly exploitable. All major issues should be fixed.
- **Critical** issues are directly exploitable security vulnerabilities. They put users' sensitive information at risk. All critical issues should be fixed.

Issue Status

- **Fixed:** The issue has been resolved.
- **Partially Fixed:** The issue has been partially resolved.
- **Acknowledged:** The issue has been acknowledged by the code owner, and the code owner confirms it's as designed, and decides to keep it.

Appendix 2

Disclaimer

This report is based on the scope of materials and documents provided, with a limited review at the time provided. Results may not be complete and do not include all vulnerabilities. The review and this report are provided on an as-is, where-is, and as-available basis. You agree that your access and/or use, including but not limited to any associated services, products, protocols, platforms, content, and materials, will be at your own risk. A report does not imply an endorsement of any particular project or team, nor does it guarantee its security. These reports should not be relied upon in any way by any third party, including for the purpose of making any decision to buy or sell products, services, or any other assets. TO THE FULLEST EXTENT PERMITTED BY LAW, WE DISCLAIM ALL WARRANTIES, EXPRESS OR IMPLIED, IN CONNECTION WITH THIS REPORT, ITS CONTENT, RELATED SERVICES AND PRODUCTS, AND YOUR USE, INCLUDING BUT NOT LIMITED TO THE IMPLIED WARRANTIES OF MERCHANTABILITY, FITNESS FOR A PARTICULAR PURPOSE, NOT INFRINGEMENT.